

Risk Acceptance Procedure

(Information Security Exception Management)



Standard Operating Procedure: Risk Acceptance Procedure

Risk Acceptance Procedure

Version	2.0
Effective Date	13/10/2025
Compiled by	Saurabh Kumar
Reviewed by	Ratnesh Singh
Approved by	Chief Information Security Officer (CISO)

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.0	19-06-2023	First Copy	Hiten Kumar	CISO	CRO
2.0	09-10-2024	RACI matrix and second level approval added, and document title updated	Ratnesh Singh	CISO	CRO
2.0	13-10-2025	No change	Saurabh Kumar	Ratnesh Singh	CISO



Standard Operating Procedure: Risk Acceptance Procedure

Contents

1. PURPOSE: 4

2. SCOPE: 4

3. DEFINITION:..... 4

4. RESPONSIBILITIES: 5

5. KEY PROCESS..... 5

6. RISK ACCEPTANCE FORM DETAILS 5

7. RISK ACCEPTANCE FORM 6

8. RACI Matrix 7

9. REVIEW:..... 7

Classification | INTERNAL



Standard Operating Procedure: Risk Acceptance Procedure

1. PURPOSE:

Risk Acceptance Procedure (Information Security Exception Management) shall be used wherever there is deviation from PFL defined policies, procedures, standards or guidelines with respect to Information Security. Risk acceptance form (RAF) shall be used to justify and validate formal information security Risk Acceptance of a known deficiency. There may be circumstances that can fall outside the ability to conform to PFL defined policies, procedures, standards or guidelines. In such instances, the risk must be documented and approved.

2. SCOPE:

RAF shall be used in circumstances where the risk is likely to exist and there is no, or minimal mitigation control exists.

- For all IT infrastructure devices (Network, Servers, and endpoints)
- For open VAPT identified risk which are not mitigated within defined closure timeline.
- During vendor due diligence / assessment, if vendor fails to comply with requirements and expectations as per infosec due diligence / assessment checklist / process.
- In case of any deviations observed during new projects or system integration or deviation from the existing process.

3. DEFINITION:

PFL	Poonawalla Fincorp Limited
CRO	Chief Risk Officer
CISO	Chief Information Security Officer
HOD	Head of Department
Risk	The potential for an event or action to have an adverse impact on the organization's objectives.
RAF	Risk Acceptance Form (RAF) is the official record / document to justify, formally accept and approval for a known risk.
Risk Acceptance	The formal approval and acknowledgement of identified risks that fall within predefined criteria and thresholds.
Asset Owner	shall be responsible for the information security of the information/information assets. Primary responsibility for defining the value and classification of assets within their control.
Application Owner	Is responsible for the management and protection of a specific application and ensure application is secure, maintained, and compliant with relevant policies and standards.
Project Owner	Is a person or group responsible for initiating, funding, and overseeing a project.
Business Owner	Is responsible to prioritizing any changes to be made to the application and authorizing the changes.
Risk Owner	is responsible for managing threats and vulnerabilities that might be exploited.
VPN	Virtual Private Network



Standard Operating Procedure: Risk Acceptance Procedure

4. RESPONSIBILITIES:

RAF Initiator	Reviewed by	1 st Level Approval	2 nd Level Approval	Final Approval	Maintained by
Asset Owner	Information Security Team	CTO & Business HOD (if required)	CISO	CRO	Information Security Team
Application Owner					
Project Owner					
Business Owner					
Functional Head					

5. KEY PROCESS

- Risk acceptance Form (RAF) is a process of documenting a risk that can be mitigated to an acceptable level. It is a means to communicate that the department / function accepts the risk, as controls, processes or resources are not available presently and cannot be implemented in a short timeline.
The RAF is reviewed and approved by the respective owner, who is accountable & responsible for the asset. An owner could be Asset owner, application owner, project owner, business owner, functional owner etc.
- By approving the RAF, the owner accepts the risk and is aware of the impact that could arise due to the potential risk and threats.
- There shall be no permanent approval for RAF. The maximum validity for RAF is maximum of 6 months (based on the severity) from the RAF approval date. Post which, the status of the RAF must be reviewed again and extension on RAF shall be provided on business need basis by respective CTO & HOD (if required), CISO, and CRO approval.
- RAF should not be accepted/initiated, if it is information security team regulatory requirement.
- The RAF shall cease to exist when the risk is remediated or brought down to an acceptable level, duly assessed by the Information security team.
- Expiry notifications will be sent by the Information security team to respective stakeholders before one month of the expiry of the respective RAF.
- RAF process shall be managed by Information security team.

6. RISK ACCEPTANCE FORM DETAILS

Basic Details:

RAF Ref No	<To be filled by infosec>
RAF title	<To be filled by infosec>
RAF Creation date	<To be filled by infosec>
RAF Approval date	<To be filled by infosec>
RAF Validity (Max 6 months)	<To be filled by infosec>

Risk Details

Standard Operating Procedure: Risk Acceptance Procedure

1. State the need and exception required in detail	<To be filled by asset owner>
2. List of affected Systems / applications	<To be filled by asset owner>
3. Risk Description	<To be filled by infosec>
4. Potential Threat / Impact	<To be filled by infosec>
5. Policy Violation Reference	<To be filled by infosec>
6. Compensatory controls implemented (if any)	<To be filled by asset owner>
7. Final Risk rating	<To be filled by infosec>
8. Controls planned to mitigate the risk	<To be filled by asset owner>
9. Action Plan & Timelines for risk mitigation	<To be filled by asset owner>
10. Timeline for closure of Risk	<To be filled by asset owner>

Risk Review and Approval

Risk Requester / Initiator	
Name	<To be filled by asset owner>
Designation	<To be filled by asset owner>
Department	<To be filled by asset owner>
Date & Sign	<To be filled by asset owner>
Risk Owner	
Name	<To be filled by asset owner>
Designation	<To be filled by asset owner>
Department	<To be filled by asset owner>
Date & Sign	<To be filled by asset owner>

7. RISK ACCEPTANCE FORMRisk Acceptance
Form.docx



Standard Operating Procedure: Risk Acceptance Procedure

8. RACI Matrix

Action Item(s)	Responsible	Accountability	Consulted	Informed
RAF Initiation	Risk Owner	Risk Owner	Information Security	HOD
RAF ID assignment & Review	Information security team	Information security team	Risk Owner	-
Obtaining Approval on RAF from respective approving authorities	Risk Owner	Risk Owner	-	HOD
Submission of approved RAF to Information Security team	Risk Owner	Risk Owner	-	-
RAF Process management including sending notification to respective risk owner	Information Security	Information Security	-	-
MIS / Reporting to Management	Information Security	Information Security	-	-

9. REVIEW:

Risk Acceptance Form SOP shall be reviewed annually or whenever any changes happen.